INCIDENT EVIDENCE WALKTHROUGH

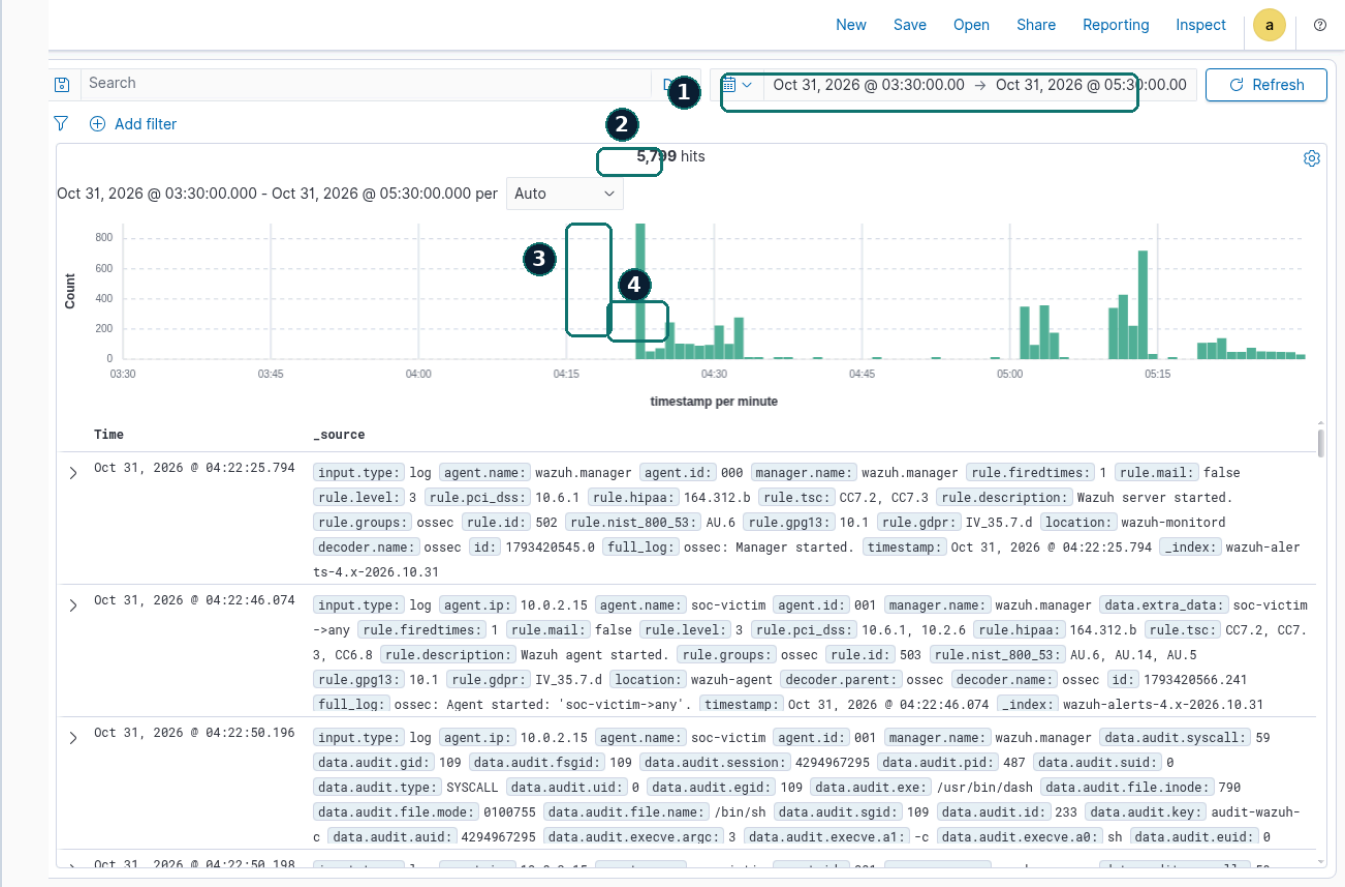
Rogue account added to sudo

INC-002 · High severity · 31 October 2026 · soc-victim

1	1	8	2 min
rogue account	sudo grant	stock hits	to removal

1. Start with the hours before

A two hour window around the account creation. 5,799 alerts, and the largest spike is a service restart rather than the incident.



1. Full window in UTC, no query, no custom rules.
2. 5,799 alerts in two hours.
3. The tall block at 04:22 is the manager and agent restarting. It is the loudest thing in the window and it is not the incident.
4. The small cluster at 04:30 is the account change. Volume is not severity, and the next pages follow this cluster.

WHAT TO LOOK FOR IN THE LOGS

Shape is not enough

A restart can outrank a compromise on a chart. Read the rule IDs before the volume.

Look for identity events

A new account is quiet, not loud. It appears as a single level 12 alert.

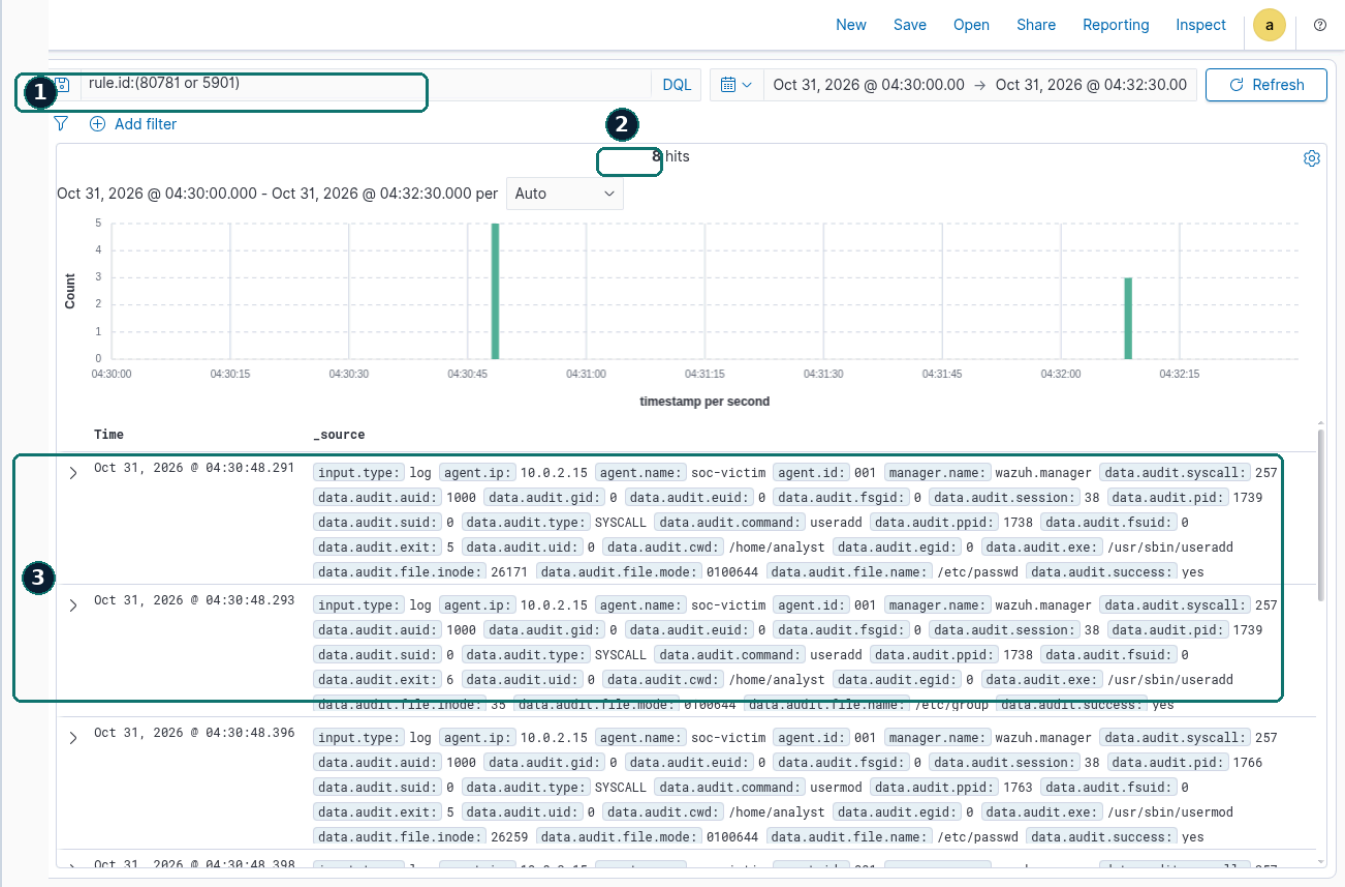
Time and account

04:30:46, one account, one administrator session.

This is why the next step filters on identity, not on volume.

2. Stock rules see the account being built

Two rules that ship with Wazuh cover the mechanics. 80781 watches writes to /etc/passwd and /etc/group, and 5901 reports a new group.



1. Query on the two stock rules.
2. Eight hits around 04:30:46, two of them at 04:32:10 when the account is removed.
3. The rows show useradd and usermod writing /etc/passwd and /etc/group, with the command and arguments.

WHAT TO LOOK FOR IN THE LOGS

Watch the identity files

/etc/passwd and /etc/group writes are the account being created.

Read the command

data.audit.command and data.audit.execve show useradd and usermod.

Correlate with sudo

Every write is preceded by a sudo session for the analyst account.

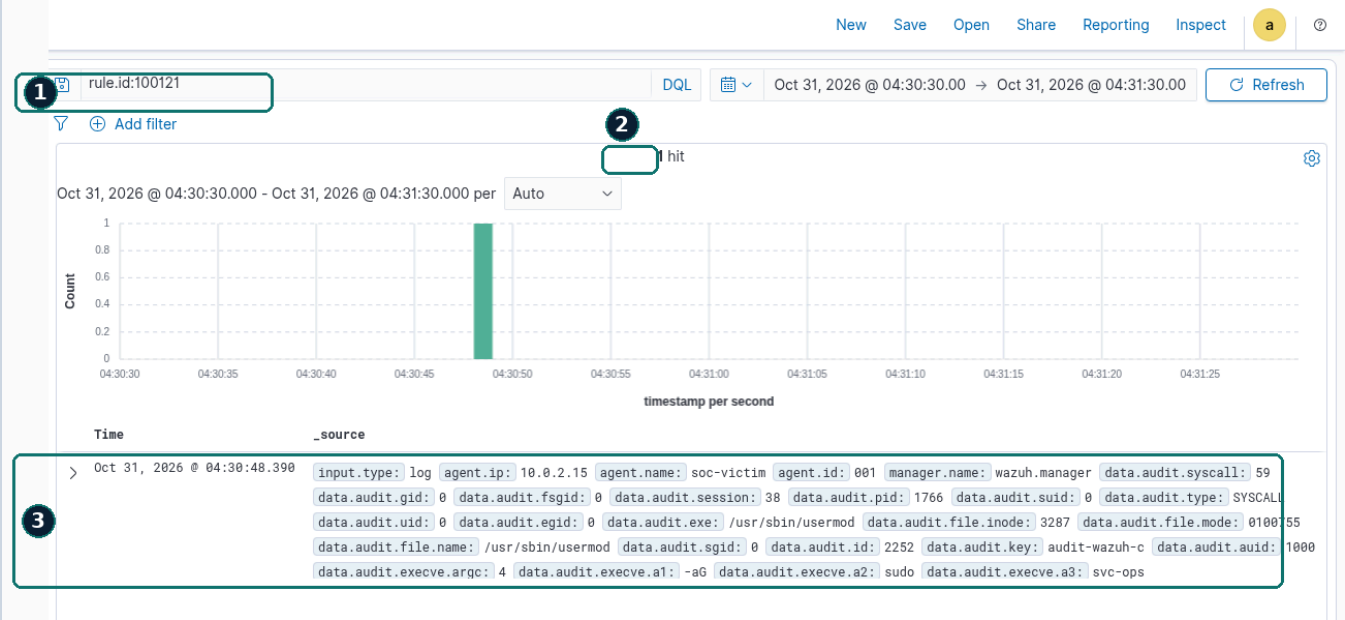
Two timestamps

Creation at 04:30 and removal at 04:32. The gap is the window to investigate.

> Stock rules show that something changed. They do not say whether the account was authorised.

3. Apply the custom rule

Rule 100121 names the privilege assignment itself: usermod -aG sudo svc-ops. That is the fact stock rules do not state.



1. Query on the custom rule only.
2. One hit at 04:30:48, one second after the account was created.
3. The row carries the command and arguments: usermod -aG sudo svc-ops.

WHAT TO LOOK FOR IN THE LOGS

Group argument

sudo, wheel, or admin in the usermod arguments.

Account argument

The account being granted privilege, svc-ops.

Level and timing

Level 12, one second after creation. That sequence is the finding.

No change record

Nothing in the change log covers a new account at 04:30.

> The custom rule turns a generic file write into a named privilege grant.

4. The account timeline

The same window exported and printed one line per alert, so the order is unambiguous.

soc-lab, INC-002, alert chain, UTC

```
$ jq -r '.[] | select(.rule.id=="5901" or .rule.id=="80781"
      or .rule.id=="100121" or .rule.id=="5402")
      | "\(.timestamp[11:19])  \(.rule.id)  \(.rule.description)"' \
      docs/evidence/INC-002-alerts.json
04:30:48  80781  Audit: Watch - Write access: /etc/passwd.
04:30:48  80781  Audit: Watch - Write access: /etc/group.
04:30:48  100121  Privilege assignment: user added to the sudo group (svc-ops)
04:30:48  80781  Audit: Watch - Write access: /etc/passwd.
04:30:48  80781  Audit: Watch - Write access: /etc/group.
04:30:48  5402  Successful sudo to ROOT executed.
04:30:48  5901  New group added to the system.
04:30:49  5402  Successful sudo to ROOT executed.
04:30:49  5402  Successful sudo to ROOT executed.
04:31:04  5402  Successful sudo to ROOT executed.
04:31:35  5402  Successful sudo to ROOT executed.
```

1. 100121 at 04:30:48 names the privilege grant.
2. 5901 at the same second reports the new group.
3. The sudo rows at 04:32 are the administrator removing the account and cleaning up.

ALERT MIX

RULE	ALERTS	WHAT IT ADDS
5901	1	New group created
80781	4	Writes to /etc/passwd and /etc/group
100121	1	svc-ops added to sudo
5402	5	Sudo sessions, creation and removal

> The removal at 04:32:07 is visible as more sudo activity. A closed ticket must show the cleanup, not just the finding.

5. Account evidence

The group membership is the proof. It survives even if the audit trail is rotated.

soc-lab, INC-002, account membership

```
$ cat docs/evidence/INC-002-membership.txt
sudo:x:27:analyst,debian,svc-ops
svc-ops:x:1003:1003::/home/svc-ops:/bin/bash
```

1. The sudo group contains svc-ops, which no change record explains.
2. The account has uid 1003, a home directory, and an interactive shell.

WHAT TO LOOK FOR IN THE LOGS

Group membership

Capture getent group sudo before deleting the account.

Account fields

uid, home, and shell. A service account should not need /bin/bash.

Hash or screenshot

Record the output as evidence for the ticket.

> Deleting the account is containment. Recording the membership first is evidence.

6. Reconstruct the commands

The audit command log gives the three commands that built the rogue account.

soc-lab, INC-002, account commands

```
$ grep -E 'useradd|chpasswd|usermod' \
    docs/evidence/INC-002-account-commands.txt
04:30:46Z  sudo useradd -m -s /bin/bash svc-ops
04:30:46Z  useradd -m -s /bin/bash svc-ops
04:30:46Z  sudo chpasswd
04:30:46Z  chpasswd
04:30:47Z  sudo usermod -aG sudo svc-ops
04:30:47Z  usermod -aG sudo svc-ops
```

1. useradd creates the account with a shell and a home directory.
2. chpasswd sets a password.
3. usermod -aG sudo grants privilege.

WHAT TO LOOK FOR IN THE LOGS

Order matters

Create, set password, grant privilege. Three commands in two seconds.

No privileged use

Check whether svc-ops ever ran sudo after the grant.

Cleanup

Removal at 04:32:07 closes the loop.

> If the account had executed a privileged command, this would escalate to Critical.

7. How to capture this evidence

1. **Start broad**

   Two hours around the event, empty query. Screenshot the histogram and note that volume can mislead.

2. **Narrow with stock rules**

   Filter on identity file writes and new groups.

   ```
   rule.id:(80781 or 5901)
   ```

3. **Apply the custom rule**

   ```
   rule.id:100121
   ```

4. **Record the membership**

   Before deleting the account, save the group line and the passwd entry.

   ```
   getent group sudo
   getent passwd svc-ops
   ```

5. **Export the alerts**

   Keep the JSON, not only the screenshot.

   ```
   curl -sk -u admin:"$WAZUH_PASS" \
     'https://localhost:9200/wazuh-alerts-*/_search?size=500' \
     -d '{"query":{"range":{"@timestamp":{"gte":"2026-10-31T04:25:00Z","lte":"2026-10-
   31T04:40:00Z"}}}}' \
     | jq '.hits.hits[]._source' > INC-002-alerts.json
   ```

> A privilege grant is only a finding if you can show the account, the group, the command, and the absence of a change record.

8. What to look for

A new account outside a change window

Any account creation needs an owner. If no ticket exists, treat it as suspicious.

Privilege granted immediately

One second between creation and the sudo grant is a pattern, not administration.

Interactive shell on a service account

/bin/bash and a home directory are unnecessary for most service accounts.

Sudo use after the grant

If svc-ops ran a privileged command, raise to Critical.

Cleanup and verification

Removal plus a group check closes the ticket.

COMMON PITFALLS

File writes are noisy

80781 fires on any write to /etc/passwd. Correlate with the command.

Volume can mislead

The largest spike in the window was a restart, not the incident.

Deleting before recording

Capture membership and uid first, or the evidence is gone.

Verdict: High severity, contained. The account was removed from sudo and deleted, with no privileged command executed. Escalated with the account details and command trail.